CASE STUDY

The FortiCloud SSO Authentication Bypass of 2026 (CVE-2026-24858): A Case Study

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

This one landed on the firewall teams who had just done the right thing. In December 2025 Fortinet fixed a FortiCloud single sign-on (SSO) login bypass [8] (**Confirmed**). Six weeks later, on 22 January 2026, Fortinet told them that someone was logging into fully upgraded FortiGate devices through FortiCloud SSO anyway, which pointed to a new attack path [2] (**Confirmed**). CISA put it plainly six days later: systems patched for the December flaws remained vulnerable [7] (**Confirmed**).

The new flaw, CVE-2026-24858, is an authentication bypass using an alternate path or channel (CWE-288). Someone holding a FortiCloud account and a registered device could log into devices registered to other accounts, as long as FortiCloud SSO was enabled on those devices [1] (**Confirmed**). Fortinet locked out the two FortiCloud accounts it found abusing it, switched FortiCloud SSO off on its own side for a day, and turned it back on only for patched versions [1] [2] (**Confirmed**). CISA added the CVE to the Known Exploited Vulnerabilities (KEV) catalog the day the CVE was published, with a three-day deadline [5] (**Confirmed**).

Key facts at a glance

Field	Value
Products	FortiOS, FortiManager, FortiAnalyzer, FortiProxy, FortiSwitchManager, FortiWeb and FortiNAC-F; Siemens RUGGEDCOM APE1808 running Fortinet NGFW below V7.4.11 [1] [11]
Flaw	Authentication bypass using an alternate path or channel (CWE-288), component GUI, discovered externally [1] [3]
Precondition	FortiCloud SSO administrative login enabled on the target; the attacker holds a FortiCloud account and a registered device [1]
Scores	CVSS 3.1 base 9.8 Critical, temporal 9.4 (Fortinet as CNA); CISA SSVC: exploitation active, automatable yes, technical impact total [1] [3] [4]
Disclosed	27 Jan 2026: advisory FG-IR-26-060; CVE reserved 15:11Z and published 19:18Z; NVD published 20:16Z [1] [3] [4]
Fixed	FortiOS 7.0.19, 7.2.13, 7.4.11 and 7.6.6, with fixes for every affected line (Part 2); last release updates added 30 Jan 2026 [1] [2]
KEV	Added 27 Jan 2026, due 30 Jan 2026; known ransomware campaign use: Unknown [5]
First seen	Arctic Wolf saw the new malicious SSO activity from 15 Jan 2026 [9] (**Reported**)
Actor	Two malicious FortiCloud accounts; no actor, group or nation named in any opened source [1] [2]
Victims	"A small number of customers" reported unexpected logins; no count, names or sectors [2]

Key findings

- **Patched for December did not mean safe in January.** Fortinet saw the attack succeed on devices fully upgraded to the latest release, and CISA says devices patched for CVE-2025-59718 and CVE-2025-59719 remained vulnerable [2] [7] (**Confirmed**).
- **A registration toggle decided exposure.** FortiCloud SSO administrative login is off in factory defaults, but registering a device to FortiCare from the GUI switches it on unless the administrator clears the "Allow administrative login using FortiCloud SSO" toggle [1] (**Confirmed**).
- **The vendor closed the door from the cloud side.** Fortinet locked out the abusing accounts, disabled FortiCloud SSO on 26 January and re-enabled it on 27 January so that it refuses logins from vulnerable versions [1] [2] (**Confirmed**). Customers must upgrade for FortiCloud SSO to work at all [1] (**Confirmed**).
- **The playbook was short and fast.** SSO login, a configuration file download and, in almost all cases, a new local administrator, with VPN access granted to the new accounts [1] [2] [7] (**Confirmed**). Arctic Wolf saw these steps seconds apart, which suggests automation [9] (**Reported**).
- **The record disagrees with itself in small ways.** The lockout date differs by a day between Fortinet's advisory and blog, KEV's description names fewer products than the advisory, and the advisory's own timeline omits the 30 January update [1] [2] [5] (**Confirmed**).
- **Nobody is named and nothing is counted.** No opened source attributes the activity or gives a victim count, and KEV records ransomware use as Unknown [1] [2] [5] (**Confirmed**).

Top recommendations

1. Upgrade every affected Fortinet product to a fixed release [1] (**Confirmed** as the vendor's direction). The 22 January blog advised disabling FortiCloud SSO administrative login until fixed [2]; since FortiCloud began refusing vulnerable versions on 27 January, the advisory says disabling it on the device is no longer necessary, though it remains a harmless belt-and-braces step [1] (**Confirmed**; the last clause **Inferred**).
2. Keep administrative interfaces off the internet: out-of-band management, or local-in policies that allowlist admin sources [2] (**Confirmed** as the vendor's direction).
3. Review every administrator account, not only the names Fortinet listed, and every VPN user and policy change [1] [2] (**Confirmed**).
4. If indicators are confirmed, treat the device and its configuration as compromised: restore a known-clean configuration and rotate every credential, including connected LDAP and Active Directory accounts [2] (**Confirmed** as the vendor's direction).
5. Assume the hashed credentials in any exported configuration can be cracked offline, and reset them even after patching [9] (**Reported** as Arctic Wolf's advice).

Scope and method

This brief covers CVE-2026-24858 from its December 2025 predecessor to the record as it stood on 11 November 2026. It describes tradecraft at advisory level. No exploit steps, request formats, attacker email addresses or IP addresses are reproduced; the generic administrator account names Fortinet published are given because defenders hunt for them.

Grade	Meaning in this study
Confirmed	Stated in a primary record opened for this study: the Fortinet advisories and PSIRT blog, the CVE, NVD and KEV records, the CISA alerts and the Siemens advisory
Reported	A third-party security vendor's report (Arctic Wolf) that the primary record does not itself state
Demonstrated	Shown by this study's own check of the library's ATT&CK, CWE, CAPEC and D3FEND data files
Inferred	This study's own reasoning from cited facts, labelled where it appears

Not checked: national CERT pages (CERT-FR, the Canadian Centre for Cyber Security, ACSC and NCSC), regulator filings, and news coverage. No news source is cited.

Part 1: what happened

Date	Event	Sources	Grade
11 Oct 2022	CVE-2022-40684, an earlier Fortinet authentication bypass, enters KEV; ransomware use Known	[5]	Confirmed
14 Jan 2025	CVE-2024-55591 enters KEV; ransomware use Known	[5]	Confirmed
18 Mar 2025	CVE-2025-24472 enters KEV; ransomware use Known	[5]	Confirmed
9 Dec 2025	Fortinet publishes FG-IR-25-647: CVE-2025-59718 and CVE-2025-59719, a FortiCloud SSO bypass via a crafted SAML message (CWE-347), CVSS 9.8, found internally	[8]	Confirmed
12 Dec 2025	Arctic Wolf sees malicious FortiGate SSO logins and configuration exports, three days after the advisory	[10]	Reported
16 Dec 2025	CISA adds CVE-2025-59718 to KEV, due 23 Dec 2025	[5]	Confirmed
15 Jan 2026	Arctic Wolf first sees a new cluster: SSO logins to admin accounts, configuration export, generic persistence accounts, VPN access changes	[9]	Reported
19 Jan 2026	Arctic Wolf's dated observations: logins from a handful of hosting providers, with login, configuration download and admin creation seconds apart	[9]	Reported
21 Jan 2026	Arctic Wolf publishes; it notes the likeness to the December campaign and says the initial access method is not yet confirmed	[9]	Reported
22 Jan 2026	Fortinet PSIRT blog: exploitation on fully upgraded devices suggests a new attack path; the advisory dates the lockout of two malicious FortiCloud accounts to this day	[1] [2]	Confirmed
23 Jan 2026	Blog update: the abused FortiCloud accounts are disabled	[2]	Confirmed
26 Jan 2026	Fortinet disables FortiCloud SSO on the FortiCloud side	[1]	Confirmed
27 Jan 2026	CVE reserved (15:11Z) and published (19:18Z); NVD entry published (20:16Z); FG-IR-26-060 published; FortiCloud SSO re-enabled, refusing vulnerable versions	[1] [3] [4]	Confirmed
27 Jan 2026	CISA adds CVE-2026-24858 to KEV "based on evidence of active exploitation", due 30 Jan 2026	[5] [6]	Confirmed
28 Jan 2026	CISA alert on Fortinet's guidance; CISA SSVC recorded in NVD (04:55Z); blog update says third-party SAML IdPs and FortiAuthenticator are not affected	[2] [4] [7]	Confirmed
30 Jan 2026	Blog: advisory updated with the last of the release updates; KEV due date for federal civilian agencies	[2] [5]	Confirmed
10 Mar 2026	Siemens SSA-975644 V1.0 lists the CVE for the FortiGate NGFW on RUGGEDCOM APE1808	[11]	Confirmed
12 May 2026	SSA-975644 V1.1 adds CVE-2025-61624 and CVE-2025-53847 (other Fortinet CVEs on the same platform)	[11]	Confirmed

Date	Event	Sources	Grade
9 Jun 2026	CVE record last updated	[3]	Confirmed
17 Jun 2026	NVD record last modified	[4]	Confirmed

Discrepancies in the record

- **The lockout date.** The advisory says the two accounts were locked out on 22 January; the blog says the abused accounts were disabled on 23 January [1] [2] (**Confirmed**). Both are Fortinet's own words, and this study gives both.
- **The advisory timeline.** FG-IR-26-060 lists only its 27 January initial publication, while the blog says the advisory was updated on 30 January with the last release updates [1] [2] (**Confirmed**). Fixed builds shipped in stages after publication (**Inferred** from [2]).
- **Product scope.** The advisory names seven product lines; the NVD description omits FortiSwitchManager; the KEV short description names only FortiAnalyzer, FortiManager, FortiOS and FortiProxy [1] [4] [5] (**Confirmed**).
- **The early SAML statement.** The blog first said the issue applied to all SAML SSO implementations, then corrected that on 28 January: third-party SAML IdPs and FortiAuthenticator are not affected [2] (**Confirmed**).
- **Two accounts or four.** The advisory says two malicious FortiCloud accounts exploited the flaw, yet lists four email identities the actor logged in with; it does not explain the difference [1] (**Confirmed**).
- **The first sighting.** Arctic Wolf's 15 January cluster predates the vendor blog by a week, but Arctic Wolf did not confirm the access method [9] (**Reported**). Linking that cluster to CVE-2026-24858 is this study's reading of the matching behavior (**Inferred**).

Part 2: the technical record

The flaw, at advisory level. FortiCloud SSO lets an administrator log into a registered device with a FortiCloud identity [1]. Fortinet says an attacker with a FortiCloud account and a registered device could use that path to log into devices registered to other accounts, if FortiCloud SSO was enabled on them [1] (**Confirmed**). Fortinet classes it as CWE-288, in the GUI component, discovered externally, and scores it CVSS 3.1 9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H) with a temporal score of 9.4 (E:H/RL:O/RC:C) [1] [3] (**Confirmed**).

How it differs from December. CVE-2025-59718 and CVE-2025-59719 were a crafted-SAML signature problem (CWE-347) that Fortinet found itself and disclosed on 9 December 2025 for FortiOS, FortiProxy, FortiSwitchManager and FortiWeb [8] (**Confirmed**). CVE-2026-24858 is a different weakness in the same login path, and patching the first did not close the second [1] [7] [8] (**Confirmed**).

Who was exposed. FortiCloud SSO administrative login is off by default. It turns on when an administrator registers the device to FortiCare from the GUI, unless the toggle is cleared during registration [1] (**Confirmed**). SSO through a custom IdP, including FortiAuthenticator, is not affected, and neither are FortiManager Cloud, FortiAnalyzer Cloud and FortiGate Cloud [1] (**Confirmed**).

Product	Affected	Fixed in
FortiOS	7.0.0 to 7.0.18, 7.2.0 to 7.2.12, 7.4.0 to 7.4.10, 7.6.0 to 7.6.5	7.0.19, 7.2.13, 7.4.11, 7.6.6
FortiManager	7.0.0 to 7.0.15, 7.2.0 to 7.2.11, 7.4.0 to 7.4.9, 7.6.0 to 7.6.5	7.0.16, 7.2.12, 7.4.10, 7.6.6
FortiAnalyzer	7.0.0 to 7.0.15, 7.2.0 to 7.2.11, 7.4.0 to 7.4.9, 7.6.0 to 7.6.5	7.0.16, 7.2.12, 7.4.10, 7.6.6
FortiProxy	7.0.0 to 7.0.22, 7.2.0 to 7.2.15, 7.4.0 to 7.4.12, 7.6.0 to 7.6.4	7.0.23, 7.2.16, 7.4.13, 7.6.5
FortiSwitchManager	7.0.0 to 7.0.7, 7.2.0 to 7.2.8	7.0.8, 7.2.9
FortiWeb	7.4.0 to 7.4.11, 7.6.0 to 7.6.6, 8.0.0 to 8.0.3	7.4.12, 7.6.7, 8.0.4
FortiNAC-F	7.6.3 to 7.6.5	7.6.6

Not affected: FortiAnalyzer 6.4, FortiManager 8.0 and 6.4, FortiNAC-F 7.4 and 7.2, FortiOS 8.0 and 6.4, and FortiWeb 7.2 and 7.0 [1] (**Confirmed**).

What the intruder did. Fortinet says the main operations were downloading the customer configuration file and adding an administrator account for persistence, with a local administrator created in almost all cases [1] [2] (**Confirmed**). The observed account names include audit, backup, itadmin, secadmin, support, backupadmin, deploy, remoteadmin, security, svcadmin, system and adccount (as Fortinet spells it); the list changed during analysis, so Fortinet advises reviewing every administrator account [1] (**Confirmed**). CISA's alert relays Fortinet's observation of unauthorized firewall configuration changes, unauthorized account creation and VPN configuration changes that gave the new accounts access [7] (**Confirmed**).

The trail it left. Fortinet's blog gives two FortiOS system events: an administrator login with method sso (logid 0100032001) and creation of a system.admin object (logid 0100044547) [2] (**Confirmed**). Arctic Wolf adds a third, a configuration download from the GUI (logid 0100032095) [9] (**Reported**).

Part 3: who and why

Who. Fortinet says two malicious FortiCloud accounts exploited the flaw [1] (**Confirmed**). The SSO login identities it lists as indicators are four FortiCloud email accounts the actor logged in with, which it expects to change because the accounts were neutralised [1] (**Confirmed**). Neither the advisory nor the blog names an actor, group or nation; both say only "the actor" [1] [2] (**Confirmed**). No opened source attributes the activity to a named group (**Confirmed** for the sources listed below).

Where from. Fortinet says the actor logged in from several IP addresses and appears to have switched to Cloudflare-protected addresses; it also lists two addresses a third party observed [2] (**Confirmed**). Arctic Wolf says the logins came from a handful of hosting providers [9] (**Reported**).

The December likeness. Arctic Wolf says the January campaign resembles the December 2025 SSO-login campaign that followed the CVE-2025-59718 disclosure, and names no actor for either [9] [10] (**Reported**). Resemblance in post-login steps is not evidence of the same operator (**Inferred**).

Why. No source states a motive. Exporting firewall configurations and planting administrator and VPN accounts buys durable access and the credentials inside the configuration (**Inferred** from [1] [9]). KEV records ransomware use as Unknown [5] (**Confirmed**).

Part 4: impact and response

Victims and scale. Fortinet says "a small number of customers" reported unexpected login activity, and that within 24 hours it found cases on fully upgraded devices [2] (**Confirmed**). No opened source gives a victim count, a named victim or a sector breakdown [1] [2] [9] (**Confirmed**).

The vendor record. Fortinet's response ran on the cloud side while fixed builds were still shipping (**Inferred** from [1] [2]): account lockout (22 or 23 January), a service-wide SSO shutdown on 26 January, and a restart on 27 January that refuses logins from vulnerable versions [1] [2] (**Confirmed**). That restart made FortiCloud SSO unusable on unpatched devices until they upgrade [1] (**Confirmed**). It corrected the SAML scope on 28 January and finished the release updates on 30 January [2] (**Confirmed**).

The government record. CISA added the CVE to KEV on 27 January, the day the CVE was published, under BOD 22-01 and "based on evidence of active exploitation", with a 30 January due date [5] [6] (**Confirmed**). The required action is to apply vendor mitigations, follow BOD 22-01 guidance for cloud services, or stop using the product, and the notes tell users to check all internet-accessible Fortinet products for compromise [5] (**Confirmed**). CISA's 28 January alert repeats that check and asks for updates to be applied as soon as they are available [7] (**Confirmed**). The SSVC decision recorded in NVD on 28 January reads exploitation active, automatable yes, technical impact total [4] (**Confirmed**).

Industrial reach. Siemens lists RUGGEDCOM APE1808, a utility-grade platform that hosts Fortinet NGFW, as affected below NGFW V7.4.11, from 10 March 2026 [11] (**Confirmed**). That is industrial reach of the flaw, not evidence of industrial victims (**Inferred**). See ICS Attacks and Advisories 2024 to 2026.

Part 5: the defender and vulnerability-management view

Configuration, not version, set the exposure. A version inventory said which devices could be hit; only the FortiCloud SSO setting said which ones were exposed [1] (**Confirmed** facts; triage reading **Inferred**). Teams that register devices from the GUI should record whether the toggle was cleared (**Inferred**).

A closed ticket is not a closed path. The December patch was correct and still left this path open [7] (**Confirmed**). Edge devices with a recent exploited login bug deserve a post-patch watch on the same feature (**Inferred**).

The clock was three days. KEV gave federal agencies until 30 January, and fixed builds were still landing that day [2] [5] (**Confirmed**). Before 27 January, disabling FortiCloud SSO administrative login and restricting the management plane were Fortinet's interim controls [2] (**Confirmed**); after that, FortiCloud's own refusal of vulnerable versions closed the SSO path until devices upgraded [1] (**Confirmed**).

Hunting. The three logids in Part 2, SSO administrator logins from Cloudflare-fronted addresses [1] [2] (**Confirmed**) or hosting providers [9] (**Reported**), new administrators with generic names and unexplained VPN user or policy changes [1] [2] [7] (**Confirmed**) are the trail. Arctic Wolf's point stands after patching: an exported configuration carries hashed credentials an attacker can crack offline [9] (**Reported**).

The lineage. Fortinet authentication bypasses CVE-2022-40684, CVE-2024-55591 and CVE-2025-24472 are all in KEV with known ransomware use [5] (**Confirmed**). Earlier Fortinet edge exploitation appears in Threat Actors: Iran, Threat Actors: China (Volt Typhoon and CVE-2022-42475), Threat Actors: Russia and Chronicle 2021.

What is overstated and what is understated

- **Overstated:** the "unauthenticated" label. The CVSS vector says no privileges, but exploitation needed an attacker-held FortiCloud account, a registered device and a target with FortiCloud SSO administrative login enabled [1] (**Inferred**). The blog's first statement that every SAML SSO setup was affected was also too broad, and Fortinet corrected it [2] (**Confirmed**).
- **Understated:** that a December patch left devices open [7]; that a GUI registration step switched the feature on [1]; and the product scope in KEV's description, which omits FortiSwitchManager, FortiWeb and FortiNAC-F [1] [5] (**Confirmed**; the KEV reading **Inferred**). Scale is unknown: with no count anywhere, "a small number of customers" is a floor of reports, not a census [2] (**Inferred**).

MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0 Enterprise, CWE, CAPEC and D3FEND. Names and tactics come from the library's `data/attack/technique_profiles.jsonl`, `superseded_by.jsonl`, `technique_to_d3fend.jsonl`, `campaigns.jsonl`, `groups.jsonl` and `data/weaknesses/` files [12] (**Demonstrated**). No source names ATT&CK technique ids; each row is this study's mapping (**Inferred**). The revoked Disable or Modify Network Device Firewall (T1562.013) resolves through `superseded_by.jsonl` to T1686.002 [12] (**Demonstrated**).

No ATT&CK for ICS table applies: Siemens's advisory puts the flaw on an industrial platform, but no source describes an industrial victim or effect [11] (**Confirmed**).

Groups, software and campaigns

No group, software or campaign object is bound. No source names an actor or a tool, and the library's ATT&CK groups and campaigns data holds no entry for this CVE or for FortiCloud SSO abuse [1] [2] [12] (**Demonstrated** for the data check).

ATT&CK Enterprise techniques

ID	Name	Tactic(s)	Dated event or report	Sources
T1585.003	Cloud Accounts	Resource Development	Attacker-held FortiCloud accounts and registered device used to log in (advisory, 27 Jan; lockout 22 Jan)	[1]
T1190	Exploit Public-Facing Application	Initial Access	FortiCloud SSO administrative login bypass on internet-facing devices (vendor blog, 22 Jan; advisory and KEV, 27 Jan)	[1] [2] [5]
T1602.002	Network Device Configuration Dump	Collection	Customer configuration file downloaded from the GUI (advisory, 27 Jan; Arctic Wolf, 21 Jan)	[1] [2] [9]
T1136.001	Local Account	Persistence	Local administrator with a generic name created in almost all cases (advisory, 27 Jan)	[1] [2]
T1133	External Remote Services	Persistence, Initial Access	VPN changes granting access to the new accounts (CISA, 28 Jan; Arctic Wolf, 21 Jan)	[7] [9]
T1686.002	Network Device Firewall	Defense Impairment	Unauthorized firewall configuration changes (CISA, 28 Jan)	[7]
T1090	Proxy	Command and Control	Logins from Cloudflare-protected addresses (vendor blog, 22 Jan)	[2]
T1119	Automated Collection	Collection	Login, export and admin creation seconds apart (Arctic Wolf, 21 Jan)	[9]

Fit notes (**Inferred**): T1585.003 rests on the advisory's attacker-held FortiCloud accounts; whether the email addresses behind them were also created by the actor is not stated, so Email Accounts (T1585.002) is not bound. T1133 is the nearest fit for VPN access given to planted accounts; no source describes a later VPN session. T1686.002 fits changes to firewall rules, but no source says whether those changes weakened protection or only opened the VPN path. T1090 assumes the Cloudflare-fronted addresses relayed the actor's traffic. T1119 rests on Arctic Wolf's reading of automation alone. Valid Accounts (T1078) is not bound: the attacker used its own FortiCloud identities, and no source describes later logins with the planted accounts.

CWE and CAPEC

CWE	Name	Where it is assigned	Sources
CWE-288	Authentication Bypass Using an Alternate Path or Channel	CVE-2026-24858 (Fortinet, NVD, KEV)	[1] [4] [5]
CWE-347	Improper Verification of Cryptographic Signature	CVE-2025-59718 and CVE-2025-59719, the December predecessor (Fortinet, KEV)	[5] [8]

CAPEC	Name	Via	Where it meets the record
CAPEC-115	Authentication Bypass	CWE-287, an ancestor of CWE-288 (through CWE-306 in CWE View-1000)	Login to other accounts' devices without their credentials [1] (**Inferred** fit)
CAPEC-475	Signature Spoofing by Improper Validation	CWE-347	The December crafted-SAML bypass [8] (**Inferred** fit)

The library relates CWE-288 directly to CAPEC-127 (Directory Indexing) and CAPEC-665 (Exploitation of Thunderbolt Protection Flaws), and CWE-347 to CAPEC-463 (Padding Oracle Crypto Attack) and CAPEC-475 (bound above); CAPEC-127, CAPEC-665 and CAPEC-463 do not meet this record [12] (**Demonstrated**). No source assigns a CAPEC id. See the CWE Reference and CAPEC Reference.

D3FEND countermeasures

D3FEND countermeasure	Techniques the library maps it to (from this study)	Where it meets the record
Inbound Traffic Filtering, Network Traffic Filtering	T1190	Local-in policies and out-of-band management for the admin interface [2]
User Geolocation Logon Pattern Analysis	T1190	SSO logins from hosting providers and Cloudflare-fronted addresses [2] [9] (**Inferred** fit)
Local Account Monitoring	T1136.001	Review all administrator accounts; system.admin creation events [1] [2]
Account Locking	T1136.001	Fortinet locked out the abusing FortiCloud accounts; disable planted admins [1] (**Inferred** fit)
User Account Permissions	T1136.001	Disable FortiCloud SSO administrative login until patched [2] (**Inferred** fit)
Session Termination	T1133	Remove VPN access given to planted accounts [2] (**Inferred** fit)

The library relates no D3FEND countermeasure to T1585.003, T1602.002, T1686.002 or T1090; it relates T1119 only to file-centred countermeasures (for example File Analysis and Restore File), none of which meets this record [12] (**Demonstrated**). Fortinet's restore and rotate guidance corresponds to Restore Configuration and Credential Rotation, which the library does not relate to these techniques [2] [12] (**Inferred**). See the D3FEND Reference.

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer pinned to ATT&CK v20, `navigator/library-layers/fortinet-forticloud-sso-cve-2026-24858.json` (open in Navigator), listed on the Navigator layers page. Each technique appears under every tactic in its library profile. Scores: 75 for behavior in the Fortinet advisory or blog or a CISA record, 50 for a third-party vendor report, 25 for an inexact fit. Each technique's comment names its source numbers.

Cross-cutting themes

- **The login path is the attack surface.** Two critical FortiCloud SSO bypasses in seven weeks hit the same feature [1] [8] (**Confirmed**). A cloud identity service wired into on-premises admin login extends the device's trust to everyone who can hold an account there (**Inferred**).
- **Vendors can now act from the cloud.** Fortinet's account lockout and server-side SSO shutdown protected customers before many could patch, and also ended SSO for anyone who stayed on vulnerable versions [1] [2] (**Confirmed**; protective effect **Inferred**).

- **Edge devices keep feeding KEV.** Three earlier Fortinet authentication bypasses carry known ransomware use in KEV [5] (**Confirmed**). See the Edge Device Security Reference.
- **Configuration export is quiet theft.** A configuration file holds credentials, VPN settings and network layout; stealing it needs no malware [1] [9] (**Inferred**).
- **Advisories keep moving.** The SAML scope and the fix list changed after first publication, and Siemens revised its advisory to add two other CVEs [2] [11] (**Confirmed**).

Sources

All sources were opened on 11 November 2026.

#	Source	URL	Opened	Grade
1	Fortinet PSIRT, FG-IR-26-060 (CVE-2026-24858), 27 Jan 2026	fortiguard.fortinet.com/psirt/FG-IR-26-060	2026-11-11	Confirmed
2	Fortinet PSIRT blog, Analysis of Single Sign-On Abuse on FortiOS, 22 Jan 2026, updated to 30 Jan 2026	fortinet.com/blog/psirt-blogs/analysis-of-sso-abuse-on-fortios	2026-11-11	Confirmed
3	CVE Program record CVE-2026-24858 (CNA Fortinet)	cveawg.mitre.org/api/cve/CVE-2026-24858	2026-11-11	Confirmed
4	NVD, CVE-2026-24858, 2.0 API record (with CISA ADP SSVC)	services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-24858	2026-11-11	Confirmed
5	CISA, Known Exploited Vulnerabilities catalog JSON (rows CVE-2026-24858, CVE-2025-59718, CVE-2022-40684, CVE-2024-55591, CVE-2025-24472)	cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-11	Confirmed
6	CISA, CISA Adds One Known Exploited Vulnerability to Catalog, 27 Jan 2026	cisa.gov/news-events/alerts/2026/01/27/...	2026-11-11	Confirmed
7	CISA alert on Fortinet guidance for the ongoing exploitation of CVE-2026-24858, 28 Jan 2026	cisa.gov/news-events/alerts/2026/01/28/...	2026-11-11	Confirmed
8	Fortinet PSIRT, FG-IR-25-647 (CVE-2025-59718 and CVE-2025-59719), 9 Dec 2025	fortiguard.fortinet.com/psirt/FG-IR-25-647	2026-11-11	Confirmed
9	Arctic Wolf Labs, Arctic Wolf Observes Malicious Configuration Changes On Fortinet FortiGate Devices via SSO Accounts, 21 Jan 2026	arcticwolf.com/resources/blog/arctic-wolf-observes-malicious-configuration-changes-...	2026-11-11	Reported
10	Arctic Wolf Labs, malicious SSO logins following disclosure of CVE-2025-59718 and CVE-2025-59719, December 2025	arcticwolf.com/resources/blog/arctic-wolf-observes-malicious-sso-logins-...	2026-11-11	Reported
11	Siemens ProductCERT, SSA-975644 (RUGGEDCOM APE1808), V1.0 10 Mar 2026, V1.1 12 May 2026	cert-portal.siemens.com/productcert/html/ssa-975644.html	2026-11-11	Confirmed
12	TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `superseded_by.jsonl`, `technique_to_d3fend.jsonl`, `groups.jsonl`, `campaigns.jsonl` (ATT&CK v20.0), and `data/weaknesses/cwe.jsonl` and `capec.jsonl`	github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-11	Demonstrated

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- ICS Attacks and Advisories 2024 to 2026, Threat Actors: Iran, Threat Actors: China, Threat Actors: Russia, Chronicle 2021, The Year 2026 in Intrusions, Timeline
- Other 2026 edge and remote-access studies: The PAN-OS GlobalProtect authentication bypass, The Cisco Catalyst SD-WAN authentication bypass, The Citrix NetScaler zero-days, The Ivanti Connect Secure zero-day chain, The BeyondTrust Remote Support and PRA command injection, Able2Shell and the RMM attack surface
- Threat Actors, Malware Families, Notable Incidents
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Edge Device Security Reference, Identity Security Reference, FortiOS, Fortinet, Vulnerability Management Reference, Vulnerability Prioritization Reference
- Techniques: T1585.003 Cloud Accounts, T1190 Exploit Public-Facing Application, T1602.002 Network Device Configuration Dump, T1136.001 Local Account, T1133 External Remote Services, T1686.002 Network Device Firewall, T1090 Proxy, T1119 Automated Collection
- CAPEC: CAPEC-115, CAPEC-475
- Navigator layers, including this study's layer, fortinet-forticloud-sso-cve-2026-24858.json
- The Team Star Wolf Intelligence Hub
- All case studies